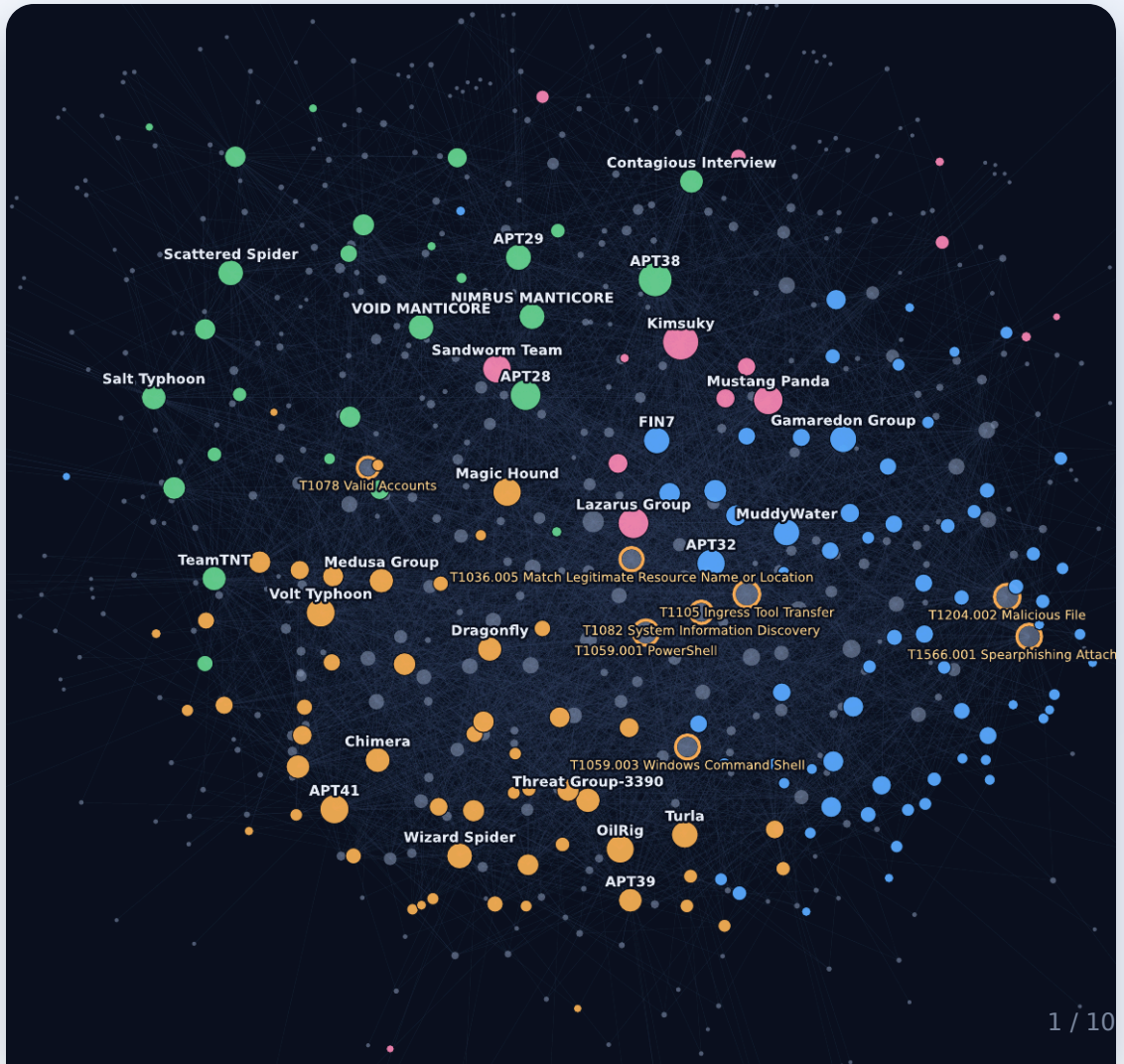
DÖNEM ÖDEVİ · AĞ ANALİZİ VE SUNUM

6 teknik, 174 tehdit grubunun %90'ını yakalamaya yetiyor

Tehdit istihbaratında iki parçalı ağ analizi
MITRE ATT&CK v20.0: 174 tehdit grubu × 515 teknik

Kaan Semih Kurt · 2516016008
Manisa Celal Bayar Üniversitesi · Büyük Veri Analistliği
Sosyal Ağ Analizi · Öğr. Gör. Osman Can Çetlenbik
30 Ekim 2026

Etkileşimli ağ: **kaansemihkurt.vercel.app/projeler/mitre-attack**
Kod ve veri: github.com/kaansemihkurt/mitre-attack-network-analysis



SORU

Savunma ekibi 515 tekniğin hepsini izleyemez: önce hangisini izlemeli?

S1. Sınırlı bütçeyle hangi teknikler öncelikle tespit edilmeli?

S2. Hangi tehdit grupları benzer davranıyor?

- **MITRE ATT&CK:** gerçek saldırılarda gözlenen davranışların açık bilgi tabanı (grup → teknik → taktik).
- Her tespit kuralı zaman ve para ister; **bütçe sınırlı**.
- **Ağ bakışı:** bir tekniğin değeri, onu kullanan grup sayısından çok *kimleri* yakaladığına bağlı.

Yöntem akışı

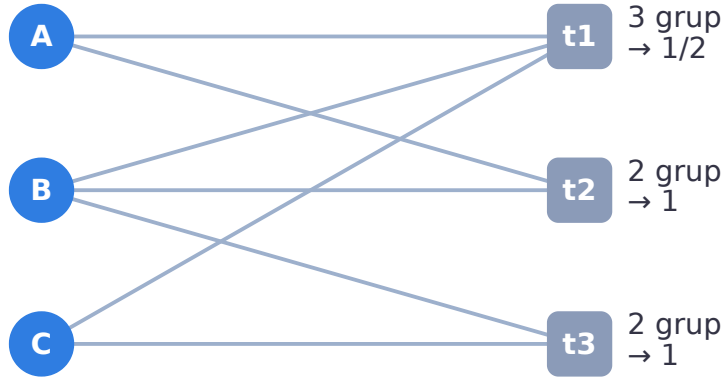
1. Veriyi script ile çek, ağı kur
2. Temel yapı ve derece dağılımı
3. Merkeziyet
4. Topluluklar (Louvain/Leiden)
5. Null model (100 rastgele ağ)
6. İleri yöntem: Newman projeksiyonu, Jaccard kümeleri, açgözlü kapsama

VERİ VE AĞ

174 grup ve 515 tekniği 4.815 “kullanır” bağıyla tek bir iki parçalı ağda birleştirdim

Karar	Seçim ve gerekçe
Kaynak	github.com/mitre/cti, sürüm etiketi **ATT&CK-v20.0**; `fetch_build.py` ile indirme, SHA-256 kaydı
Düğüm	Tehdit grubu (174) + teknik/alt-teknik (515; 335'i alt-teknik)
Kenar	“Grup X, teknik Y'yi kullanır”; **yönsüz, ağırlıksız** (ATT&CK sıklık vermiyor)
Alt-teknik	Ayrı düğüm: tespit kuralları bu düzeyde yazılır; toplansaydı 378 düğüm (<500)
Filtre	İptal edilmiş / eskimiş kayıtlar ve hiç kullanılmayan 191 teknik çıkarıldı
Çıktı	edges.csv, nodes.csv, 3 GraphML, veri sözlüğü, lisans notu

İki parçalı ağ ve projeksiyon



Grup–grup projeksiyonu: ortak teknik = bağ. 174 düğüm, 11.776 kenar.

TEMEL YAPI

Her grup ATT&CK'in yalnızca küçük bir parçasını kullanıyor, ama kopuk tek bir grup bile yok

0,054
iki parçalı yoğunluk: olası çiftlerin %5'i

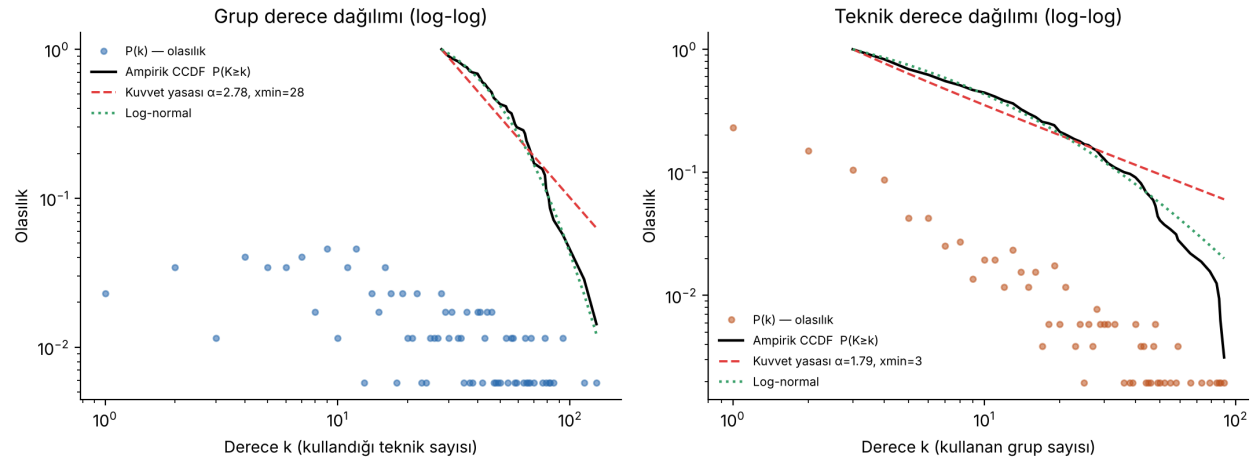
1
bileşen: her grup en az bir tekniği paylaşıyor

3,13 / 7
ort. yol / çap: iki grup tipik olarak tek ortak teknikle bağlı

-0,28
assortativity: nadir teknikler çok belgelenmiş gruplarda

0 / 0,11
kümelenme: üçgen yok / Latapy iki parçalı katsayı

19 / 4
medyan: grup başına teknik / teknik başına grup



Teknik derecesi ağır kuyruklu (T1105: 90 grup), ama **log-normal kuvvet yasasından daha iyi** ($R = -4{,}2$, $p < 0{,}001$): “ölçekten bağımsız” demek yanlış olur.

MERKEZİYET

Ağın merkezinde herkesin kullandığı teknikler var: Ingress Tool Transfer, PowerShell, hazır araçlar

#	Derece	Grup	Betweenness
1	T1105 Ingress Tool Transfer	90	T1588.002 Tool
2	T1204.002 Malicious File	87	T1059.001 PowerShell
3	T1059.001 PowerShell	86	T1105 Ingress Tool Transfer
4	T1588.002 Tool	84	T1204.002 Malicious File
5	T1566.001 Spearphishing Attachment	79	T1566.001 Spearphishing Attachment
6	T1059.003 Windows Command Shell	73	T1059.003 Windows Command Shell

- Ölçüler arası **Spearman 0,86–0,99**: bu ağda “merkezi” teknik büyük ölçüde “yaygın” teknik demek.
- **T1588.002 Tool** betweenness'ta 1.: Mimikatz, Cobalt Strike gibi hazır araçlar farklı grup ailelerini birbirine bağlıyor.
- Köprü teknik örneği: **T1120** yalnız 9 grup, ama betweenness sırası 31.
- Grup tarafında Kimsuky, APT38, APT28, Lazarus en merkezde: bu **raporlanma yoğunluğu**, tehlike sıralaması değil.

TOPLULUKLAR

Gruplar ülkeye göre değil saldırı tarzına göre 4 davranış ailesine ayrışıyor

Oltalama ve zararlı belgeyle sızanlar

75 grup · ör. APT32, Gamaredon Group, MuddyWater, FIN7

Ayırt edici: Drive-by Compromise, Visual Basic, Spearphishing Attachment

Ağ içi keşif ve yanal hareket ustaları

56 grup · ör. APT41, Volt Typhoon, Magic Hound, OilRig

Ayırt edici: Local Account, SMB/Windows Admin Shares, Domain Accounts

Bulut, Linux ve güvenilen ilişki saldırganları

28 grup · ör. APT38, APT28, APT29, NIMBUS MANTICORE

Ayırt edici: Cloud Accounts, Unix Shell, Trusted Relationship

Sosyal mühendislik ve kimlik bilgisi avcıları

15 grup · ör. Kimsuky, Lazarus Group, Mustang Panda, Sandworm Team

Ayırt edici: Search Victim-Owned Websites, Email Addresses, Steal Web Session Cookie

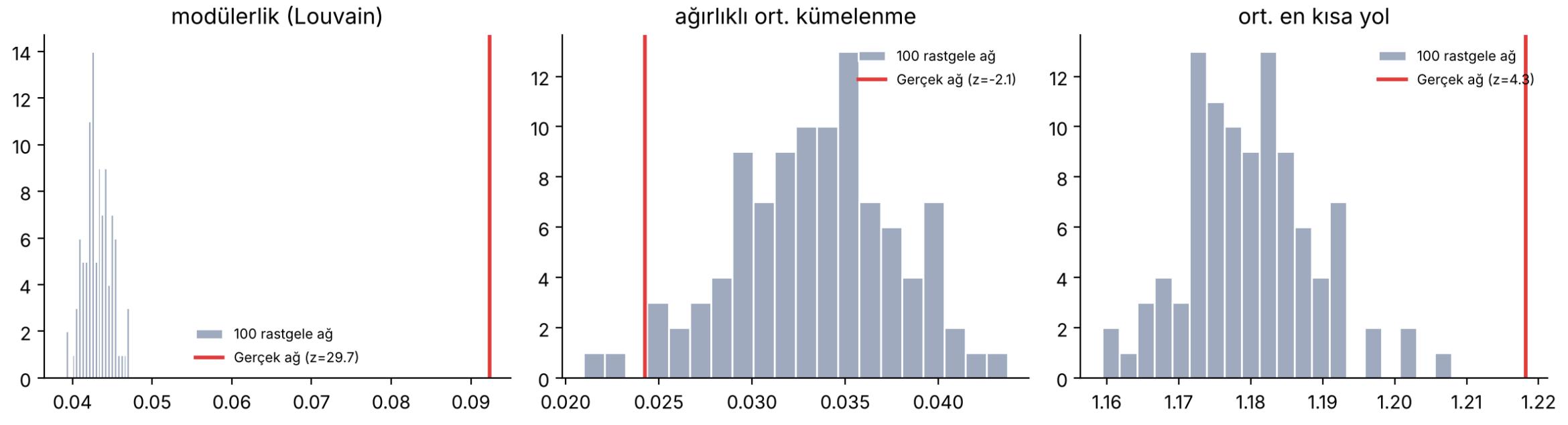
Louvain = Leiden (NMI = 1,0) · modülerlik **0,092** · 10 tohumda NMI ≈ 0,69, ARI ≈ 0,74: çekirdek kararlı, sınırdaki gruplar oynak. Newman ağırlıklı grup projeksiyonu; adlar ayırt edici tekniklere (lift) göre verildi.

● CANLI GÖSTERİM

Etkileşimli ağda bir topluluğu seç ve bir grubu (ör. APT29) aç

NULL MODEL

Topluluk yapısı rastlantı değil (z ≈ 30), ama yüksek kümelenme rastlantı (z ≈ -0,5)

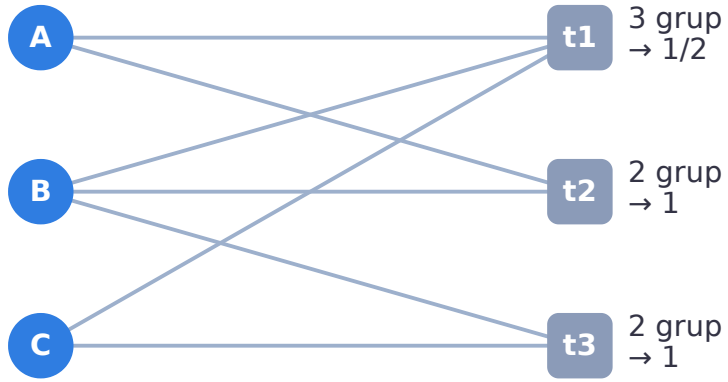


Null model: grupların ve tekniklerin derecesini koruyarak kenarları karıştırdım (iki parçalı kenar takası), **100 rastgele ağ** ürettim. Neden Erdős–Rényi değil? Projeksiyon popüler teknikler yüzünden zaten yoğun ve üçgenli; ER ile kıyaslamak bu etkiyi "bulgu" sandırır.

Null model olmasaydı: "grup projeksiyonunda kümelenme 0,89, gruplar çok kümelenmiş" derdik; oysa rastgele ağlarda da 0,895. Asıl bulgu modülerlik: 0,092, rastgele 0,043 ± 0,002.

Newman ağırlığı nadir ortak teknikleri öne çıkarıyor: en güçlü bağ LAPSUS$ ↔ Scattered Spider

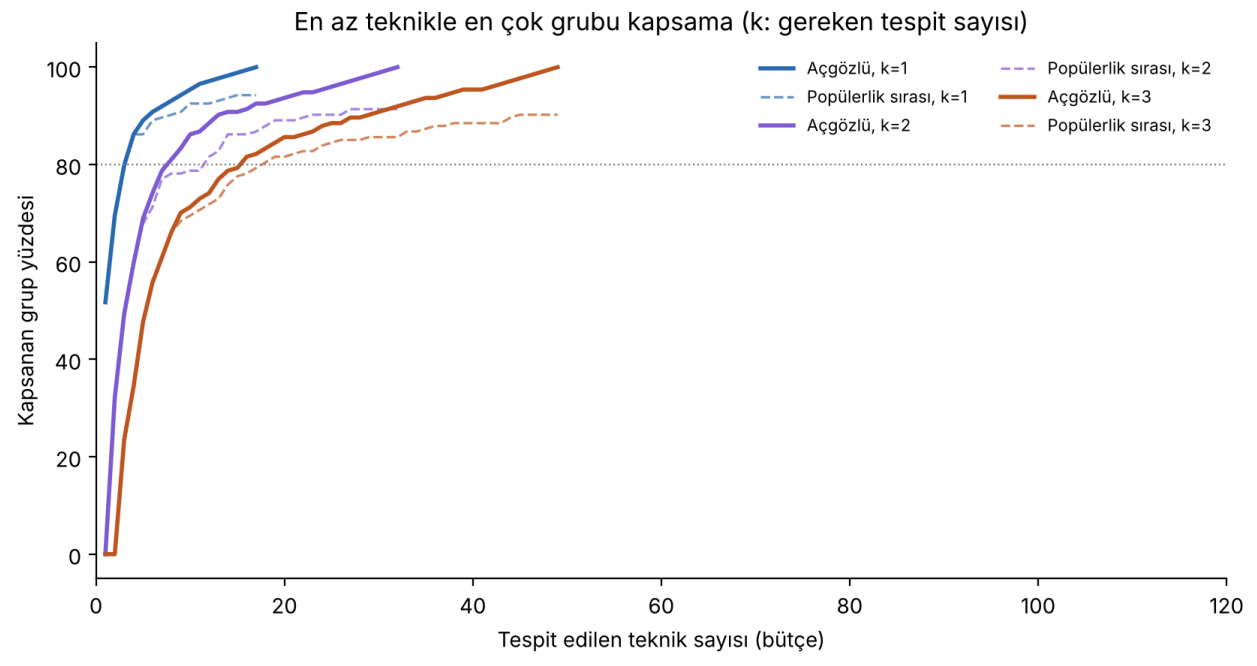
Newman (2001): $w_{ij} = \Sigma\ 1/(d_k - 1)$



A–B = 1/2 + 1 = **1,5** · B–C = **1,5** · A–C = **0,5** (yalnız herkesin kullandığı t1)

- **Ham ortak teknik sayısı** en çok belgelenmiş grupları öne çıkarıyor: APT38–Kimsuky (60 ortak).
- **Newman** nadir paylaşımları öne çıkarıyor: **LAPSUS$–Scattered Spider** (5,65; 21 ortak). İkisi de sosyal mühendislik ve kimlik bilgisiyle ilerleyen gasp grupları.
- İki sıralama benzer (Spearman 0,92), ama en güçlü 10 bağın yalnız 3'ü ortak.
- **Jaccard** (|ortak| / |birleşim|), k-NN ağı ve Leiden ile **5 küme** (modülerlik 0,53). Casusluk (APT28, APT29, APT41, Volt Typhoon) ve fidye (Wizard Spider, Medusa) **aynı kümede**: ağ içinde aynı teknikler (RDP, SMB, uzak sistem keşfi).
- En benzer büyük çift: **Patchwork–Sidewinder** (J = 0,39, 20 ortak teknik).

Açgözlü seçim 17 teknikle tüm grupları kapsıyor; popülerlik sırası 203 teknik istiyor



6
teknik → %90 (k=1)

16
teknik → %80 (k=3)

49
teknik → %100 (k=3)

#	Öncelik listesi (tespit edilebilir, k = 3)	Grup	Küm.
1	T1105 Ingress Tool Transfer	90	%1,1
2	T1204.002 Malicious File	87	%1,1
3	T1059.001 PowerShell	86	%24,7
4	T1059.003 Windows Command Shell	73	%38,5
5	T1566.001 Spearphishing Attachment	79	%50,0
6	T1036.005 Match Legitimate Resource Name or Location	66	%56,3
7	T1078 Valid Accounts	49	%62,1
8	T1082 System Information Discovery	59	%67,2
9	T1190 Exploit Public-Facing Application	47	%70,7
10	T1071.001 Web Protocols	58	%73,6

Her adımda henüz kapsanmayan grupları en çok ilerleten teknik seçilir; k = grubu yakalamak için gereken tespit sayısı. Keşif / Kaynak Geliştirme teknikleri (ağ dışında olur) çıkarıldı.

SONUÇ VE SINIRLAR

Cevap: 10 teknikle başla, tamamlayıcıları ekle; bulgular raporlanan davranışı yansıtır, nedenselliği değil

S1. PowerShell, Ingress Tool Transfer, zararlı dosya, oltalama eki, Windows komut satırı, geçerli hesap… İlk 10 teknik grupların **%74'ini** en az 3 noktadan görünür kılıyor. Sonra popüler olanı değil, *henüz yakalanmayan grubu* yakalayanı ekle.

S2. 4 davranış ailesi: oltalama, ağ içi yanal hareket, bulut/Linux/güvenilen ilişki, sosyal mühendislik. Aileler ülke atıflarını kesiyor; “kim” değil “nasıl” saldırdığı belirleyici.

Sınırlar

- **Raporlama yanlılığı:** çok raporlanan grup daha çok teknikle görünür.
- Kenarlar ikili ve zamansız; kampanya/yazılım üzerinden dolaylı teknikler dahil değil.
- Kapsama ≠ tespit kalitesi; açgözlü çözüm optimum değil (≤ ln n + 1 katı).
- Modülerlik düşük (0,09); sınırlar yumuşak.
- **Nedensellik yok:** aynı tekniği kullanmak iş birliği ya da aynı ülke demek değil.